

PsExec Hunt

CyberDefenders Blue Team Lab -- Network Forensics

Category: Network Forensics | Difficulty: Easy | Tool: Wireshark

MITRE ATT&CK Tactics: Execution, Defense Evasion, Discovery, Lateral Movement

The Scenario (in simple words)

An Intrusion Detection System (IDS) flagged suspicious activity involving a tool called **PsExec**. This tool is normally used by IT admins to remotely run programs on other computers on the network -- but it can just as easily be abused by an attacker who has stolen valid login credentials. Our job was to trace the attacker's movement from computer to computer using only the network capture.

Background: what is PsExec, and why do attackers use it?

PsExec is a legitimate Microsoft (Sysinternals) tool. An admin points it at a remote computer, and it connects over the network file-sharing protocol (SMB), copies over a small helper program, installs it as a temporary Windows service, and uses that service to run whatever command was requested -- then cleans up afterward. Attackers love this technique because it uses a completely legitimate, trusted Windows tool instead of custom malware, making it much harder for antivirus software to flag as suspicious. This is often called *"living off the land."*

What Actually Happened (the story)

The attacker's own machine, hostname **HR-PC**, first connected to a machine called **SALES-PC** and logged in using a valid Windows account named **ssales**. Once authenticated, the attacker connected to two special hidden network shares that exist on every Windows machine: **IPC\$** (used for management communication) and **ADMIN\$** (a hidden share that maps directly to the Windows installation folder, C:\Windows). Through ADMIN\$, the attacker uploaded a file named **PSEXESVC.exe** -- exactly the filename the real PsExec tool uses -- which Windows then registered and ran as a service, giving the attacker the ability to execute commands on SALES-PC.

The attacker didn't stop there. From the same HR-PC machine, they attempted to pivot again, this time to a third machine, **MARKETING-PC**. Their first login attempt used a username **jdoe**, which failed. They then tried again with a different account, **IEUser**, which succeeded -- showing the attacker was testing multiple stolen or guessed credentials until one worked, then repeating the exact same PsExec technique to spread further across the network.

Step-by-Step Investigation

Step 1 -- Find the attacker. Opened Statistics > Conversations > IPv4 tab, sorted by Bytes. One IP, 10.0.0.130, stood out with two separate large conversations while everything else was tiny background traffic -- a strong sign of an attacker reaching out to multiple targets.

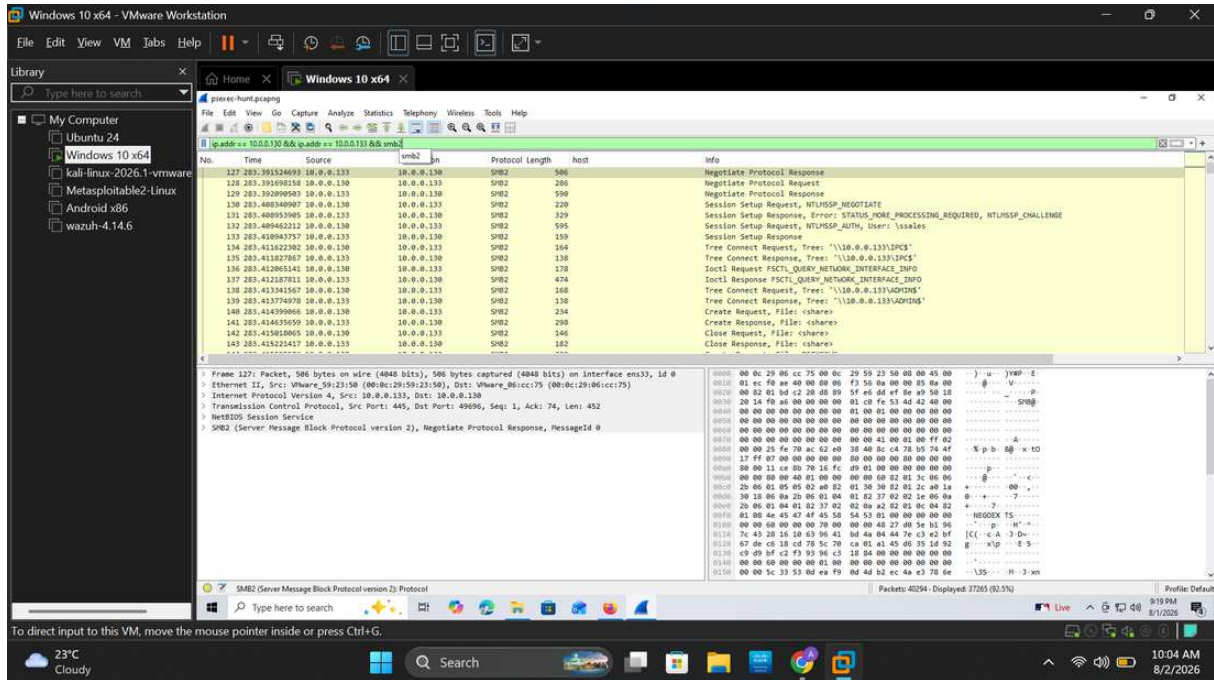


Fig 1 -- Conversations view: 10.0.0.130 has two heavy conversations, marking it as the attacker.

Step 2 -- Confirm the SMB/PsExec pattern. Filtered on `ip.addr == 10.0.0.130 && ip.addr == 10.0.0.133 && smb2` to isolate traffic between the attacker and the first target. The sequence matched textbook PsExec behavior: Negotiate Protocol, Session Setup (NTLM authentication), then Tree Connect requests to IPC\$ and ADMIN\$.

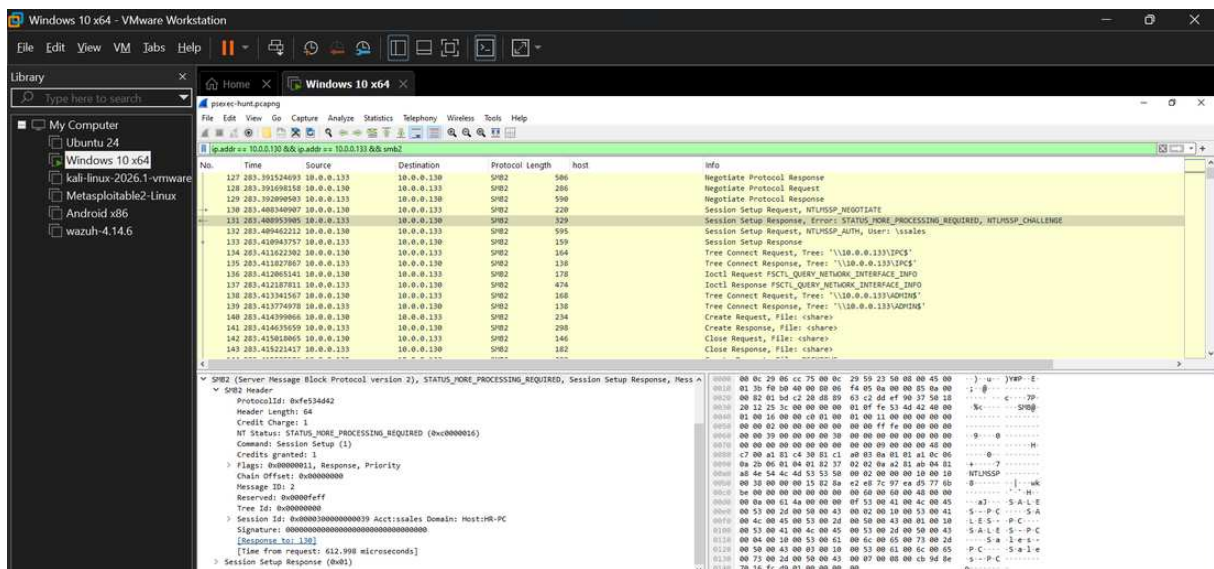


Fig 2 -- The classic PsExec SMB sequence: authentication, then Tree Connect to IPC\$ and ADMIN\$.

Step 3 -- Identify the target's hostname. Opened the NTLMSSP_CHALLENGE packet (the server's response during authentication) and drilled down through SMB2 > Session Setup Response > NTLM Secure Service Provider > NTLM Server Challenge to find the Target Name field, which revealed the hostname in plain text.

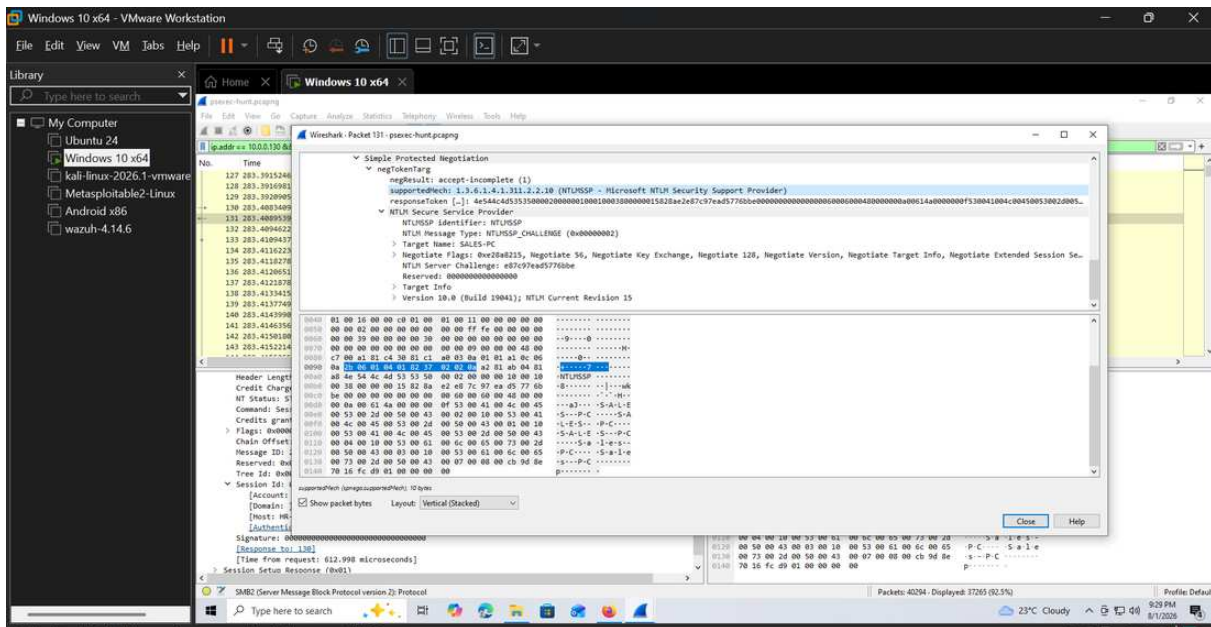


Fig 3 -- The NTLM authentication challenge reveals the first victim's hostname: SALES-PC.

Step 4 -- Find the dropped service executable. Continued through the same filtered stream and located Create Request / Write Request rows, which showed the exact filename being written to the target machine over the ADMIN\$ share.

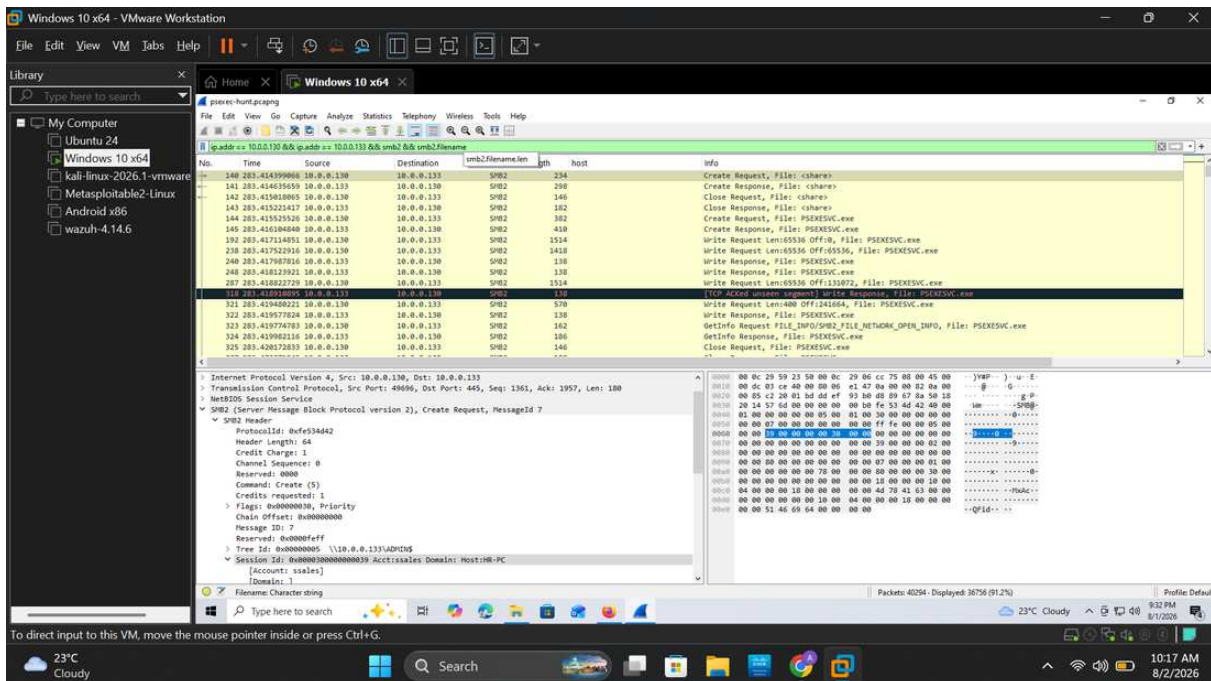


Fig 4 -- The attacker creating and writing PSEXESVC.exe onto the target machine through ADMIN\$.

Step 5 -- Look for further lateral movement. Went back to the Conversations list and checked the second heavy conversation (10.0.0.130 to 10.0.0.131). Filtering the same way revealed a failed login with username jdoe, immediately followed by a successful one using a different account, IEUser.

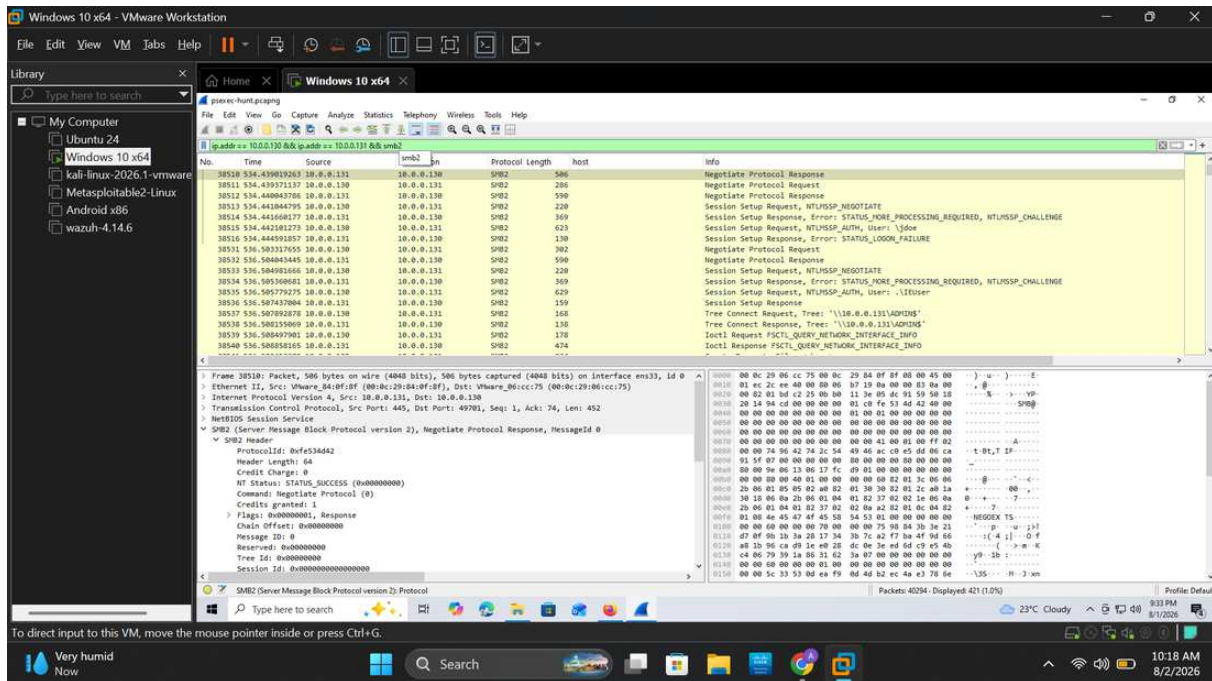


Fig 5 -- A failed login attempt with jdoe, immediately followed by a successful one using IEUser.

Step 6 -- Identify the second target's hostname. Same technique as Step 3, applied to the successful authentication -- expanded the NTLM Server Challenge and read the Target Name field.

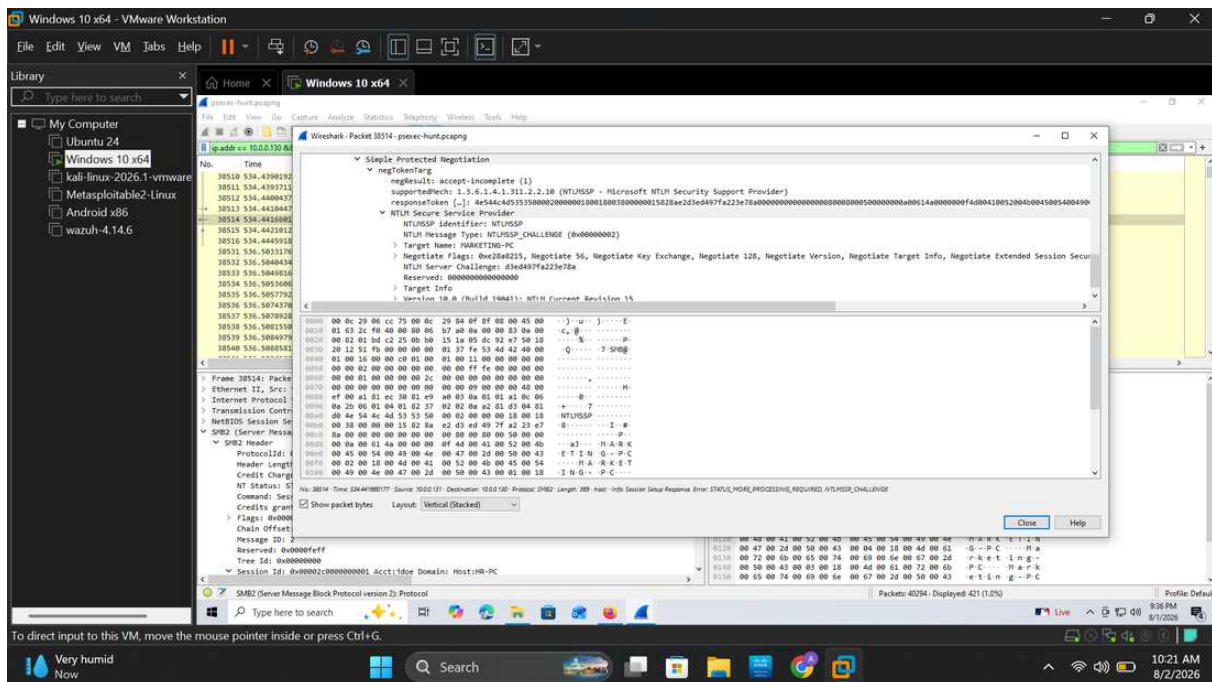


Fig 6 -- The NTLM challenge for the second pivot target reveals its hostname: MARKETING-PC.

Final Answers

Q	Question (short)	Answer
Q1	Attacker's initial IP address	10.0.0.130
Q2	Hostname of first pivoted machine	SALES-PC
Q3	Username used for authentication	ssales
Q4	Service executable name	PSEXESVC.exe
Q5	Share used to install the service	ADMIN\$
Q6	Share used for communication	IPC\$
Q7	Hostname of second pivoted machine	MARKETING-PC

Protocol Glossary

SMB (Server Message Block)	The core Windows networking protocol for sharing files, printers, and other resources between computers. When you open a network folder like \\SERVER\Shared on Windows, SMB is what makes that work behind the scenes.
SMB2	The modern version of SMB used by current Windows systems. Almost all PsExec-style traffic uses SMB2, and every field of the conversation (login, share connection, file read/write) is broken down under this protocol label in Wireshark.
ADMIN\$	A hidden, built-in Windows share pointing directly at the Windows installation folder (normally C:\Windows). Only administrators can access it. PsExec uses it to drop an executable directly onto the target machine's system folder.
IPC\$	Another hidden built-in share, used not for files but for inter-process communication -- querying services or exchanging authentication messages. PsExec uses this channel to install and control the remote service.
NTLM (NT LAN Manager)	A Windows authentication protocol. The server sends a random "challenge," and the client responds with proof it knows the password, without sending the password itself in plain text. Usernames, domains, and hostnames often appear in this exchange.
NTLMSSP_NEGOTIATE / CHALLENGE / AUTH	The three stages of an NTLM login: the client says it wants to authenticate, the server replies with a challenge (often revealing its own hostname), and the client sends back proof plus its own username and hostname.
Session Setup Request/Response	The SMB2 commands that carry out the NTLM login process described above.
Tree Connect Request	The SMB2 command used to "connect" to a specific network share (e.g. ADMIN\$ or IPC\$) before reading, writing, or running anything on it.
Create Request/Response	The SMB2 equivalent of opening or creating a file on the remote share -- used here when PSEXESVC.exe was written onto the target.

Wireshark Filters & Actions Used

Statistics > Conversations > IPv4 (sort by Bytes)	Spot the attacker by unusually heavy traffic between specific IP pairs
ip.addr == A && ip.addr == B && smb2	Show only SMB2 traffic between two specific machines
Expand Session Setup Response > NTLM Secure Service Provider > NTLM Server Challenge > Target Name	Reveals the target machine's hostname, sent by the server during the NTLM challenge step
Expand Session Setup Request > Session Id > Account / Host	Reveals the username and the client's own hostname used for that login attempt
Reading Tree Connect Request/Response rows in the Info column	Directly shows which network share (ADMIN\$, IPC\$, etc.) was accessed, in plain text
Reading Create Request/Response, Write Request rows	Shows the exact filename being written to the remote share, e.g. PSEXESVC.exe

Personal learning log from the CyberDefenders SOC Analyst Tier 1 track. All lab data belongs to CyberDefenders; this document reflects my own investigation process and findings.